

Bypassing Firewall Filtering on Ports 80 & 443

Alternative TCP Port Scanning Analysis & Kali Linux Code Reference

Problem Statement & Scenario

When a firewall is configured to block or filter standard web ports (HTTP port 80 and HTTPS port 443), standard SYN (-sS) or Connect (-sT) scans receive no response and result in a 'filtered' status. To determine whether the service is truly listening behind the firewall or to identify the firewall's rule state, alternative scanning techniques (ACK, FIN, NULL, and Idle Scans) must be utilized.

Analysis of Alternative Scanning Techniques

1. TCP ACK Scan (-sA)

- **Mechanism:** Sends raw TCP packets with only the ACK flag set.
- **Firewall Behavior Analysis:** Stateless firewalls only inspect individual packet headers and allow ACK packets through, assuming they belong to an established connection. The host receives the ACK and sends back a RST frame (port is 'unfiltered'). Stateful firewalls track connection state; unsolicited ACK packets without an active handshake are dropped (port remains 'filtered').
- **Primary Purpose:** Differentiates between stateful and stateless firewall rulesets.

2. TCP FIN (-sF) & NULL (-sN) Scans

- **Mechanism:** FIN scan sends packets with only the FIN flag set; NULL scan sends packets with no flags set.
- **Firewall Behavior Analysis:** Firewalls that only block incoming connection requests (by looking specifically for the SYN flag) allow FIN and NULL probes to pass through. According to RFC 793, if the target port is closed, the target OS responds with a RST packet. If the port is open, the target OS silently discards the packet.
- **Primary Purpose:** Passes through non-stateful SYN filters to verify if a port is open on RFC 793-compliant systems (Linux, Unix, BSD). Note: Windows systems send RST regardless.

3. TCP Idle / Zombie Scan (-sl)

- **Mechanism:** Exploits predictable IP ID sequence generation on a third-party host ('zombie') to perform a completely blind scan using spoofed IP addresses.
- **Firewall Behavior Analysis:** If a firewall filters probes coming from the attacker's IP address, the attacker spoofs packets so they appear to come from an IP address trusted/whitelisted by the firewall (the zombie host). By probing the zombie's IP ID changes before and after sending spoofed SYN probes to the target, the attacker determines if the target sent a SYN-ACK back to the zombie.
- **Primary Purpose:** Bypasses IP-based firewall filtering and provides true stealth/anonymity.

Technique Comparison Matrix

Scan Type	Flag Set	Stateless Response	Stateful Response	Target Compatibility
ACK (-sA)	ACK	RST (Unfiltered)	No response (Filtered)	All Systems
FIN (-sF)	FIN	RST (Closed) / None (Open)	Dropped (Filtered)	Linux/Unix (RFC 793)
NULL (-sN)	None	RST (Closed) / None (Open)	Dropped (Filtered)	Linux/Unix (RFC 793)
Idle (-sl)	SYN (Spoofed)	Depends on Zombie IP ID	Depends on Zombie IP ID	Requires Predictable Zombie

Kali Linux Executable Code Reference

- 1. Map Firewall Rulesets on Ports 80 & 443 (ACK Scan)

```
sudo nmap -sA -p 80,443 target_ip
```

- 2. Probe Non-Stateful Filters on Ports 80 & 443 (FIN Scan)

```
sudo nmap -sF -p 80,443 target_ip
```

- 3. Probe Non-Stateful Filters on Ports 80 & 443 (NULL Scan)

```
sudo nmap -sN -p 80,443 target_ip
```

- 4. Blind Spoofed Scan using Zombie Host (Idle Scan)

```
# Step 1: Find a suitable zombie candidate with predictable IP ID
```

```
sudo nmap --script ipidseq -iR 1000 -p 80
```

```
# Step 2: Perform Idle scan targeting ports 80 and 443 via Zombie IP
```

```
sudo nmap -sI zombie_ip -p 80,443 target_ip
```